Sri Lanka Institute of Information Technology



IE3122-Network Security

Year 3, Semester 1- 2026

NORTHBRIDGE SAVINGS & FINANCE

Network Security Upgrade Assignment

Assignment 01 Group 73

Member Name	Student Number
Kumarasinghe K W A DT P	IT24102485
Bogahapitiya B L B K	IT24102626
Ariyapperuma A A D C	IT24103108
Arachchi B A A A B	IT24102592

Contents

1. Executive Summary
2. Assignment Requirements and Mark Alignment
3. Northbridge Current Security Posture
4. Individual Threat Modelling
5. Combined Layered Security Plan
6. Group Technology Evaluation and Final Selection
7. Proposed Secure Network Architecture
8. Network Hardening Configurations in Cisco Packet Tracer
9. Practical Validation Summary
10. Limitations and Implementation Notes
11. Conclusion
Appendix A. Member 1 Individual Technology Proposals
Appendix B. Member 2 Individual Technology Proposals
Appendix C. Member 3 Individual Technology Proposals
Appendix D. Member 4 Individual Technology Proposals
Appendix E. Consolidated Configuration Scripts
Appendix F. Evidence Register
References

1. Executive Summary

Northbridge Savings & Finance is a mid-sized regional financial-services provider with a head office, six branches, approximately 450 staff, an on-premises core banking environment, public online/mobile services, remote users, external support contractors, and planned integrations with two payment-processing partners. The scenario exposes major weaknesses including a historically flat network, shared remote-access credentials, no MFA, limited firewall protection, no IDS/IPS, decentralised authentication, weak patching and logging practices, untested recovery processes, physical-security gaps, and limited security governance.

The proposed upgrade follows a layered security model. It combines segmentation, firewall boundaries, central AAA, secure remote connectivity, monitoring, patch and vulnerability management, awareness training, tested recovery, third-party controls, physical controls, and account policy. Twelve controls are deliberately reused across multiple threats so that the design minimises unnecessary control count while still preserving defence in depth.

The practical Packet Tracer component contains eight individually attributable hardening configurations: extended ACL-based segmentation, switch port security, DHCP snooping, Dynamic ARP Inspection (DAI), RADIUS-based AAA, an IPsec site-to-site VPN implementation, a management-plane ACL, and SSH-only device administration. The first five have been configured in the current build; the VPN and Member 4 evidence must be finalised and captured before submission. This report does not claim a successful VPN security association until that evidence exists.

2. Northbridge Current Security Posture

Domain	Observed weakness	Security consequence
Identity and access	No MFA; shared VPN identity; local accounts; password reuse/sharing	Weak accountability and high credential-reuse impact
Network architecture	Guest, branch, user and sensitive systems have historically shared excessive reachability	Large lateral-movement and reconnaissance surface
Detection	No IDS/IPS and no centralised monitoring capability	Slow discovery of compromise and weak investigation capability
Endpoint security	Outdated branch systems and no formal patch process	Known vulnerabilities remain exploitable
Physical security	Shared server-room key; unlocked branch cabinets; limited surveillance	Physical tampering may bypass logical controls
Third-party risk	Two payment partners added without a mature vendor-assessment process	New trust boundary can become a high-impact attack path
Resilience	Backups untested; no formal DR/IR process	Recovery from ransomware or major outage is uncertain
Human factors	No formal security-awareness programme; recent helpdesk impersonation attempt	Social engineering can bypass technical controls

The highest-value assets are customer financial and personal data, the core banking application and database, public online/mobile services, employee identities, branch-to-HQ connectivity, and the upcoming payment-partner integrations. Northbridge therefore needs security controls that reduce lateral movement, protect trust boundaries, strengthen accountability, and improve detection and recovery.

3. Individual Threat Modelling

Each threat uses the required Asset -> Vulnerability -> Threat -> Exploit -> Attack -> Impact -> Risk sequence. Risk ratings are justified using facts from the Northbridge scenario rather than generic statements.

T1. Ransomware lateral movement from a compromised branch workstation (Member 1)

Stage	Analysis
Asset	Core banking database, core applications, branch systems, and service availability
Vulnerability	Branch systems are historically over-connected and some branch endpoints are outdated, allowing a compromised workstation to reach sensitive systems.
Threat	Ransomware operator
Exploit	A branch endpoint is compromised through phishing, exploitation, or malicious software.
Attack	The attacker executes ransomware, steals credentials/tools, and moves laterally through reachable internal segments.
Impact	Core banking and branch services may become unavailable; transactions and operational processing may be disrupted.
Risk	Very High - the scenario specifically highlights ransomware incidents beginning with a single branch workstation and spreading through an unsegmented network.

T2. Unauthorised device attachment through an accessible switch port (Member 1)

Stage	Analysis
Asset	Head-office and branch access switches, endpoint traffic, and local network availability
Vulnerability	User-facing or unused access ports can be abused where there is no device-level port control.
Threat	Unauthorised user or attacker with local access
Exploit	The attacker obtains physical access to an accessible switch port.
Attack	A rogue laptop/device is connected, joins a trusted VLAN, and is used for reconnaissance or further access.
Impact	Unauthorised network presence, interception opportunities, policy bypass, or a foothold for lateral movement.
Risk	High - weak physical control over branch/back-office equipment makes an unapproved device a credible direct entry point.

T3. Rogue DHCP server attack (Member 2)

Stage	Analysis
Asset	Client addressing, DNS/gateway trust, and internal network traffic
Vulnerability	Without DHCP snooping, clients may accept DHCP replies from an unauthorised server.
Threat	Attacker operating a rogue DHCP service
Exploit	A malicious device is placed on a user network and responds to DHCP requests.
Attack	Clients receive attacker-controlled gateway or DNS settings and route/resolve traffic through malicious infrastructure.
Impact	Credential theft, redirection, interception, disruption, and a platform for further attacks.
Risk	High - reliable addressing and gateway integrity are important for staff, branch, guest and payment-support environments.

T4. ARP spoofing and man-in-the-middle attack (Member 2)

Stage	Analysis
Asset	Layer-2 traffic, staff credentials, and application sessions
Vulnerability	Without Dynamic ARP Inspection, a malicious host can manipulate IP-to-MAC bindings in the local broadcast domain.
Threat	On-path attacker in the same Layer-2 network
Exploit	Forged ARP advertisements claim to be a gateway or trusted host.
Attack	Victim traffic is redirected through the attacker, who can observe, alter, or selectively drop packets.
Impact	Credential exposure, session hijacking, data tampering, and availability loss.
Risk	High - local MITM attacks are particularly serious where staff and banking-related traffic traverse trusted access networks.

T5. Abuse of shared remote-access credentials (Member 3)

Stage	Analysis
Asset	Remote-access service and internal systems
Vulnerability	Remote users and contractors share one VPN identity with no individual accountability and no MFA.
Threat	Attacker who obtains the shared VPN credential
Exploit	The shared credential is obtained through phishing, leakage, password reuse, or insider disclosure.
Attack	The attacker establishes remote access under the shared identity and attempts internal access.
Impact	Unauthorised access, poor attribution, lateral movement, and delayed incident response.
Risk	Very High - remote access is required by staff and contractors while the shared identity prevents reliable accountability.

T6. Credential compromise through password reuse and sharing (Member 3)

Stage	Analysis
Asset	Employee accounts, network administration, applications, and internal services
Vulnerability	Password reuse/sharing and multiple local account stores increase credential exposure and reuse opportunities.
Threat	Credential thief
Exploit	One reused or shared password is obtained from a compromised system, social engineering, or accidental disclosure.
Attack	The credential is reused across applications/devices and may be used to escalate access.
Impact	Account takeover, fraud, unauthorised access, and wider lateral movement.
Risk	High - one compromised password can become a wider identity compromise when credentials are reused and local accounts are widespread.

T7. Compromise of a public-facing online banking system (Member 4)

Stage	Analysis
Asset	Online banking portal, mobile-facing services, customer data, and reputation
Vulnerability	Public-facing services are Internet-exposed while the existing environment lacks dedicated firewall and IDS/IPS capability.
Threat	External attacker exploiting a public-facing weakness
Exploit	The attacker discovers an exposed service and abuses an application or configuration weakness.
Attack	The public-facing system is compromised, data is stolen/manipulated, or movement toward internal systems is attempted.
Impact	Customer data exposure, fraud, service outage, regulatory consequences, and reputational damage.
Risk	Very High - customer-facing financial systems have direct financial and regulatory consequences if compromised.

T8. Unauthorised administration of network devices (Member 4)

Stage	Analysis
Asset	Routers, switches, firewall devices, configurations, and network control plane
Vulnerability	Management access historically relies on local accounts and weak management-path restrictions.
Threat	Unauthorised or compromised administrator
Exploit	An attacker obtains credentials or reaches a device management interface from an unauthorised network.
Attack	The attacker logs in and changes routes, ACLs, accounts, or interface settings.
Impact	Loss of availability, policy bypass, persistent access, traffic interception, or full control of security infrastructure.
Risk	Very High - network-device compromise can disable other controls and directly affect branch/core connectivity.

4. Combined Layered Security Plan

The combined plan uses twelve broad controls. Controls are intentionally reused across threats so that the design minimises unnecessary control count while retaining deliberate defence-in-depth overlap.

ID	Control	Purpose	Threats
C1	Network segmentation and security zones	Separate Internet/DMZ, server, staff, finance, admin, guest, branch, payment, remote and management networks with explicit routing and least-privilege rules.	T1,T3,T4,T5,T7
C2	Multi-layer firewall architecture	Use perimeter and internal firewall boundaries with explicit zone policy and deny-by-default where practical.	T1,T4,T7,T8
C3	Named remote-access VPN with MFA	Replace shared VPN identity with named users, strong authentication, MFA and controlled resource access.	T5,T6
C4	Centralised AAA	Centralise authentication, authorisation and accounting for network and administrative access.	T5,T6,T8
C5	IDS/IPS capability	Detect/prevent scanning, exploitation, malicious traffic and lateral movement at critical boundaries.	T1,T3,T4,T7,T8
C6	Patch and vulnerability management	Maintain inventory, vulnerability process, patch schedule and exception handling.	T1,T7
C7	Security awareness and social-engineering training	Train staff on phishing, impersonation, password requests, reporting and suspicious communications.	T5,T6,T7
C8	Centralised logging and security monitoring	Collect and correlate events from network, AAA, VPN, servers, endpoints and security controls.	T1,T3,T4,T5,T6,T7,T8
C9	Backup, restore testing and disaster recovery	Maintain protected backups, verify restoration and define recovery roles/priorities.	T1,T7
C10	Third-party security assessment and controlled integration	Assess payment partners and restrict integration using explicit trust boundaries and allow-listed flows.	T7
C11	Physical access control and surveillance	Use accountable physical access, locked cabinets/server rooms and suitable monitoring.	T2,T8
C12	Password and account policy	Enforce unique credentials, prohibit sharing, reduce local-account sprawl and manage privileged accounts.	T5,T6,T8

4.1 Control-to-Threat / Attack Mapping

Control	Threats addressed
C1	T1,T3,T4,T5,T7
C2	T1,T4,T7,T8
C3	T5,T6
C4	T5,T6,T8
C5	T1,T3,T4,T7,T8
C6	T1,T7
C7	T5,T6,T7
C8	T1,T3,T4,T5,T6,T7,T8
C9	T1,T7
C10	T7
C11	T2,T8
C12	T5,T6,T8

4.2 Function x Category Dual-Axis Classification

Function	Category	Controls
Preventive	Administrative	C6, C7, C10, C12
Preventive	Technical	C1, C2, C3, C4, C5
Preventive	Physical	C11
Detective	Administrative	C6, C7, C10
Detective	Technical	C5, C8
Detective	Physical	C11
Deterrent	Administrative	C7, C10, C12
Deterrent	Technical	C2, C5
Deterrent	Physical	C11
Corrective	Administrative	C6, C7, C10
Corrective	Technical	C2, C5, C6
Corrective	Physical	C11
Recovery	Administrative	C9
Recovery	Technical	C9
Recovery	Physical	C11

Compensating	Administrative	C7, C10, C12
Compensating	Technical	C5, C8
Compensating	Physical	C11

Controls appear in multiple cells only where they genuinely serve multiple functions or categories. For example, C8 is primarily detective/technical, while C11 provides preventive, detective and deterrent value at the physical layer and can also support recovery/compensating arrangements.

4.3 Control Minimisation Justification

The plan deliberately avoids creating a separate control for every symptom. C1 segmentation reduces ransomware blast radius, isolates guest access, narrows local Layer-2 exposure and limits remote/branch reachability. C4 central AAA and C12 account policy jointly address shared credentials, local account sprawl and privileged-access weaknesses. C8 central monitoring gives these identity and network controls a common investigation trail instead of requiring a separate monitoring product for each threat.

A narrower approach would create separate controls for each branch VLAN, each remote-access abuse case, each password problem, each public-facing attack type and each third-party connection. That would increase administrative complexity without a proportional security improvement. The twelve-control model instead addresses root causes and reuses controls across multiple threats.

Some redundancy is retained deliberately. C2 firewall boundaries and C5 IDS/IPS overlap because a firewall enforces allowed reachability while IDS/IPS detects or blocks malicious behaviour that may occur on an otherwise permitted path. C11 physical security also overlaps with C2/C4 because physical access can bypass logical controls. This overlap is justified by the high consequence of financial-system compromise.

5. Group Technology Evaluation and Final Selection

The Excellent rubric requires all four proposals to be compared directly using the same criteria and requires the report to explain why the rejected options were not selected. The following tables use Northbridge fit, security capability, manageability, interoperability/scalability and operational burden as common criteria.

5.1 VPN

Member proposal	Northbridge fit	Security / interoperability	Operational view	Decision
M1 - IPsec VPN	Strong for branch/site-to-site and can support enterprise remote-access designs	Network-layer protection; broad Cisco/enterprise interoperability	More configuration effort but mature and auditable	CHOSEN
M2 - WireGuard	Excellent simplicity for modern endpoints but weaker fit for mixed legacy/enterprise site integration	Strong modern cryptography; fewer native enterprise identity/legacy integrations	Low complexity, but less aligned to existing Cisco-style infrastructure	Rejected
M3 - OpenVPN	Good for user remote access and mixed endpoint support	Flexible client compatibility; less natural as a single standard for site-to-site Cisco routing	Manageable for users, but introduces another platform	Rejected
M4 - SSL VPN	Very good user experience for travelling staff/contractors	Strong for application/user remote access; not the best common branch/site solution	Simple for users, but does not cover site-to-site need as cleanly	Rejected

Final selection: IPsec VPN. It is the only proposal that cleanly covers the requirement for secure site-to-site connectivity while remaining widely interoperable with enterprise routing and firewall platforms. WireGuard and OpenVPN are attractive for user access, and SSL VPN is strong for usability, but the group needed one common network-layer technology that also fits dedicated branch/site connectivity.

5.2 AAA

Member proposal	Northbridge fit	Security / accountability	Operational view	Decision
M1 - RADIUS	Good for broad user/network-access authentication	Centralises authentication; weaker command-level device authorisation than TACACS+	Widely supported and simple	Rejected as sole final choice

M2 - TACACS+	Excellent for network-device administration	Separates AAA functions and supports granular admin accountability	Strong fit for routers/switches	CHOSEN
M3 - TACACS+	Excellent for privileged infrastructure access	Detailed authorisation/accounting improves traceability	Consolidated with M2	CHOSEN strength
M4 - RADIUS + directory	Excellent for user identity across services	Good central identity; broader than the network-device admin focus	Useful as complementary service	Rejected as sole final choice

Final selection: TACACS+ for production network-device AAA. RADIUS remains useful for user/network access, but TACACS+ better fits the assessment and operational need for administrator accountability and command-level control. The Packet Tracer practical in Section 8 demonstrates RADIUS because that is the working lab implementation; it does not replace the group production recommendation.

5.3 Secure Network Architecture

Proposal	Northbridge fit	Strength	Limitation / decision
M1 - Three-zone / multi-firewall	Strong	Separates Internet/DMZ, internal banking, users and branches	Chosen foundation; expanded with more trust zones
M2 - DMZ + internal segmentation with dual firewalls	Strong	Adds second enforcement boundary after public services	Chosen foundation; final design adds payment/management zones
M3 - DMZ + segmented internal + dedicated payment zone	Very strong	Directly addresses two new payment partners as a distinct trust boundary	Payment-zone requirement retained
M4 - Zero-trust-inspired micro-segmentation	Strategically strong	Reduces implicit trust and focuses access on resources	Applied as a principle; full micro-segmentation is beyond Packet Tracer scope

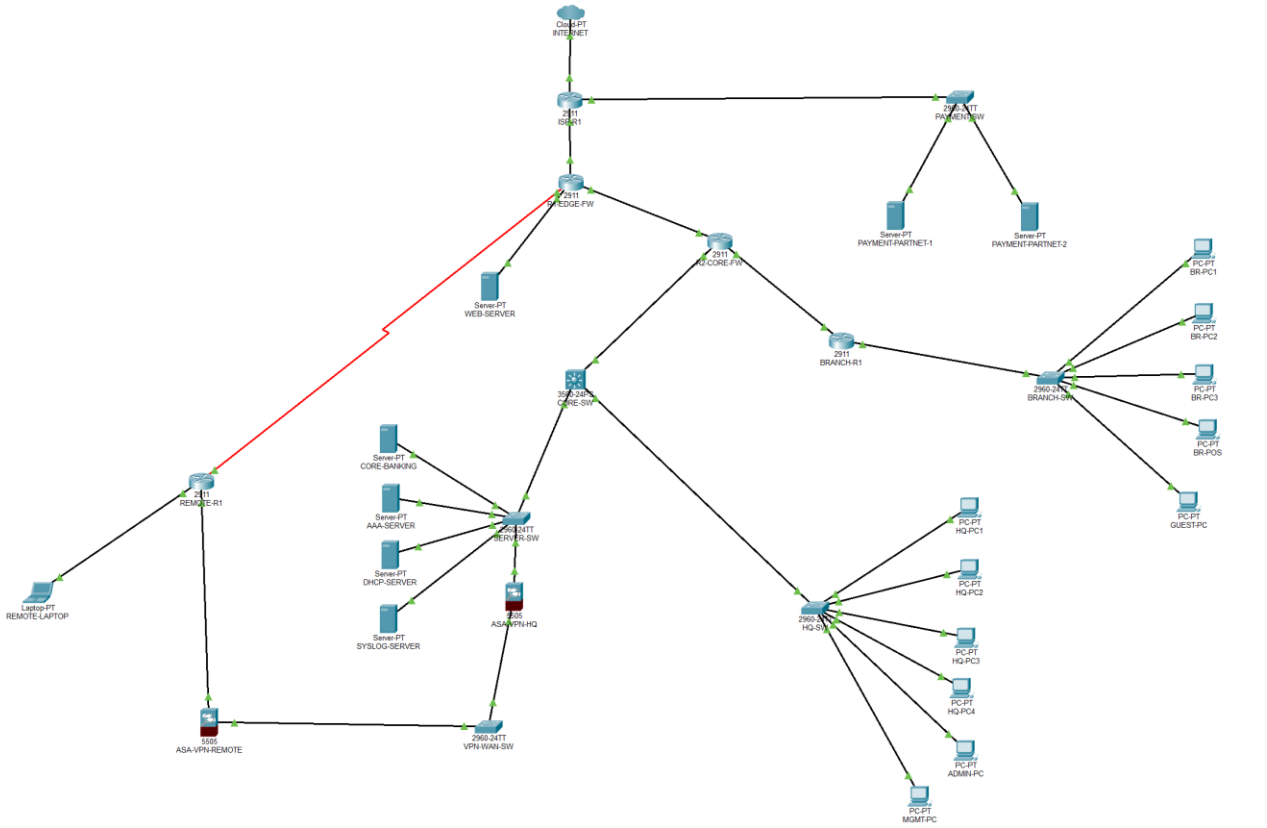
Final selection: multi-firewall, multi-zone architecture. The final design combines an Internet edge, DMZ, internal server boundary, user/finance/admin/guest zones, branch zones, a dedicated payment-partner zone, a management zone and a remote/VPN trust boundary. Zero-trust principles are applied conceptually through least privilege and reduced implicit trust.

5.4 IDS/IPS

Proposal	Northbridge fit	Strength	Limitation / decision
M1 - Suricata	Strong	Flexible signatures, open deployment model	Strong option; requires operational tuning/management
M2 - Snort	Strong	Mature rule ecosystem and wide familiarity	Strong option; separate deployment/management needed
M3 - Commercial NGFW IPS	Very strong for a financial institution	Integrated policy, prevention, visibility and central management	CHOSEN assuming budget approval
M4 - Suricata	Strong	Flexible strategic monitoring at several boundaries	Strong but more integration effort than the selected managed platform

Final selection: centrally managed commercial NGFW IPS at critical boundaries. Northbridge has high-value customer and transaction systems, so integrated prevention, visibility and support are prioritised over the lower acquisition cost of an open-source deployment. Packet Tracer is not used to claim a production-grade IPS implementation.

6. Network Architecture



Zone	Representative subnet/system	Security intent
Internet edge	203.0.113.0/30; ISP-R1 / EDGE-R1	External connectivity and perimeter boundary
HQ core transit	10.0.0.0/30	Controlled routing path between EDGE-R1 and CORE-SW1
HQ Staff VLAN 10	192.168.10.0/24	Corporate staff endpoints
HQ Finance VLAN 20	192.168.20.0/24	Finance endpoints
HQ Admin VLAN 30	192.168.30.0/24	Administrative endpoints
HQ Guest VLAN 40	192.168.40.0/24	Untrusted access blocked from internal networks
HQ Server VLAN 50	192.168.50.0/24	Core banking, RADIUS, DHCP, DNS, SYSLOG
Management VLAN 60	192.168.60.0/24	Restricted management source zone
DMZ	192.168.70.0/24	Public WEB/DNS isolated from internal servers
Branch Staff VLAN 110	192.168.110.0/24	Branch staff
Branch Finance VLAN 120	192.168.120.0/24	Branch finance
Branch Management VLAN 130	192.168.130.0/24	Branch administration/management
Payment partner network	172.16.100.0/24	Dedicated third-party trust boundary
Remote user LAN	192.168.100.0/24	Remote-side protected network
VPN WAN	172.16.200.0/30	Transit between VPN-REMOTE-R1 and VPN-HQ-R1
VPN HQ transit	10.254.100.0/30	Controlled path from VPN-HQ-R1 to CORE-SW1

Guest-to-internal traffic is filtered at the core, server and management functions are placed in separate VLANs, public services are isolated in a DMZ, branch networks use separate subinterfaces/VLANs, and payment processors are treated as an external trust boundary. The conceptual production design adds stronger stateful firewall and IDS/IPS enforcement than Packet Tracer can fully emulate.

7. Network Hardening Configurations in Cisco Packet Tracer

Member	Configuration	Plan link	Primary threat/status
Member 1	Extended ACL + network segmentation	C1 / C2	T1 - verified
Member 1	Switch Port Security	Free choice	T2 - verified
Member 2	DHCP Snooping	C1 / C5 supporting	T3 - verified
Member 2	Dynamic ARP Inspection	C1 / C5 supporting	T4 - configured; capture final evidence
Member 3	RADIUS AAA	Free choice / supports C4	T5,T6,T8 - verified
Member 3	IPsec Site-to-Site VPN	C3	T5 - PENDING final verification
Member 4	Management-plane ACL	C2 / C4 supporting	T8 - capture final evidence
Member 4	SSH-only management	C4	T8 - capture final evidence

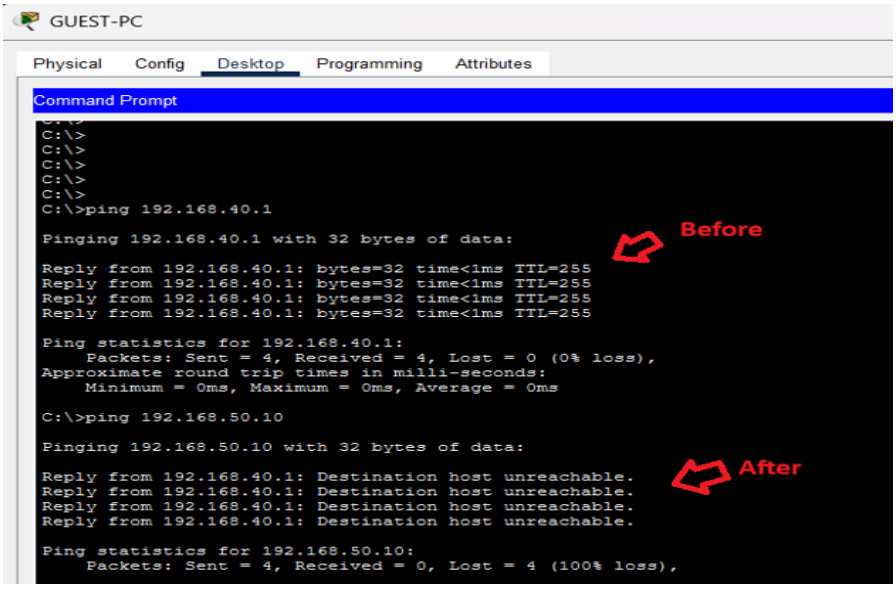
7.1 Extended ACL and Network Segmentation (Member 1)

Purpose: isolate the untrusted Guest VLAN 40 from staff, finance, admin, server and management networks while allowing other required traffic.

Plan/threat linkage: implements C1 segmentation (and supports C2 policy enforcement) for T1 by reducing unnecessary reachability and ransomware/lateral-movement paths.

```
enable
configure terminal
ip access-list extended GUEST-FILTER
 deny ip 192.168.40.0 0.0.0.255 192.168.10.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.20.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.30.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.50.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.60.0 0.0.0.255
 permit ip 192.168.40.0 0.0.0.255 any
exit
interface vlan 40
 ip access-group GUEST-FILTER in
exit
end
```

Verification: show access-lists; guest-to-server ping should fail while authorised staff-to-server traffic remains available. Packet Tracer may not display the SVI ACL perfectly in show ip interface, so ACL match counters and the traffic outcome are the primary evidence.



7.2 Switch Port Security (Member 1)

Purpose: restrict STAFF-SW1 Fa0/1 to one learned sticky MAC address and shut the port if a different device violates the policy.

```
enable
configure terminal
interface fastEthernet0/1
 switchport mode access
 switchport access vlan 10
 switchport port-security
 switchport port-security maximum 1
 switchport port-security mac-address sticky
 switchport port-security violation shutdown
 spanning-tree portfast
 no shutdown
exit
end
```

Verification: show port-security interface fa0/1; show port-security address. A temporary second device can be connected to demonstrate a psecure violation and secure-shutdown/err-disabled state, followed by authorised recovery.

Before

```
STAFF-SW1#show port-security interface fa0/1
Port Security              : Disabled
Port Status                : Secure-down
Violation Mode             : Shutdown
Aging Time                 : 0 mins
Aging Type                 : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses      : 1
Total MAC Addresses        : 0
Configured MAC Addresses   : 0
Sticky MAC Addresses       : 0
Last Source Address:Vlan   : 0000.0000.0000:0
Security Violation Count   : 0
STAFF-SW1#
```

After

```
STAFF-SW1#show port-security interface fa0/1
Port Security              : Enabled
Port Status                : Secure-up
Violation Mode             : Shutdown
Aging Time                 : 0 mins
Aging Type                 : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses      : 1
Total MAC Addresses        : 1
Configured MAC Addresses   : 0
Sticky MAC Addresses       : 1
Last Source Address:Vlan   : 0060.2FCD.B077:10
Security Violation Count   : 0
```

7.3 DHCP Snooping (Member 2)

Purpose: establish trusted DHCP paths and prevent rogue DHCP replies on the staff access VLAN. The legitimate DHCP server is 192.168.50.12 and CORE-SW1 relays VLAN 10 requests using ip helper-address.

```
! CORE-SW1
interface vlan 10
 ip helper-address 192.168.50.12

! STAFF-SW1
configure terminal
ip dhcp snooping
ip dhcp snooping vlan 10
interface gigabitEthernet0/1
 ip dhcp snooping trust
exit
interface range fastEthernet0/1-2
 ip dhcp snooping limit rate 10
exit
end

! DHCP-SRV STAFF-POOL
Default Gateway: 192.168.10.1
DNS Server: 192.168.50.13
Start IP: 192.168.10.100
Mask: 255.255.255.0
Maximum Users: 50
```

Verification: Staff clients obtained DHCP leases and STAFF-SW1 learned DHCP snooping bindings. The server/uplink path is trusted while access ports remain untrusted.

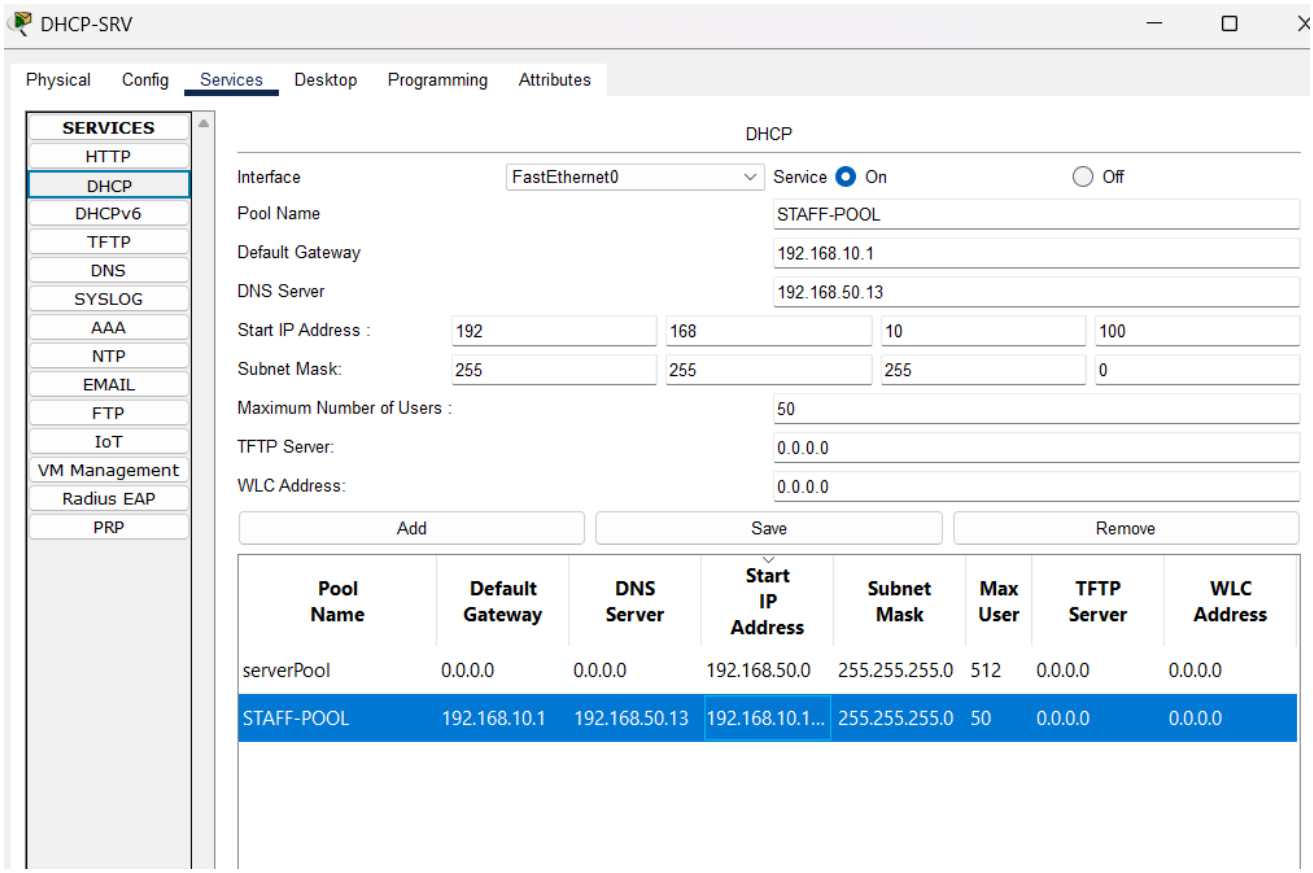


Figure 3. DHCP-SRV STAFF-POOL configured for VLAN 10 clients.

```
STAFF-SW1#show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
10
Insertion of option 82 is enabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                  Trusted    Rate limit (pps)
-----------------------    -------    ----------------
FastEthernet0/2            no         10
FastEthernet0/1            no         10
GigabitEthernet0/1         yes        unlimited
```

DHCP Snooping Enabled

```
STAFF-SW1#show ip dhcp snooping binding
MacAddress          IpAddress        Lease(sec)  Type           VLAN  Interface
------------------  ---------------  ----------  -------------  ----  ------------------
00:00:0C:11:7C:76   192.168.10.101   0           dhcp-snooping  10    FastEthernet0/2
Total number of bindings: 1
```

DHCP Snooping Binding Table

7.4 Dynamic ARP Inspection (Member 2)

Purpose: validate ARP traffic on VLAN 10 using the DHCP snooping binding database and a trusted uplink, reducing local ARP spoofing/MITM risk.

```
enable
configure terminal
ip arp inspection vlan 10
interface gigabitEthernet0/1
 ip arp inspection trust
exit
end

show ip arp inspection
show ip dhcp snooping binding
```

Practical note: Packet Tracer may show zero DAI counters even when the feature is enabled and valid traffic is passing. The report should therefore include the enabled VLAN/trusted interface output, DHCP bindings, and a successful legitimate gateway ping.

```
STAFF-SW1#show ip arp inspection

Source Mac Validation      : Disabled
Destination Mac Validation : Disabled
IP Address Validation      : Disabled

 Vlan     Configuration    Operation   ACL Match          Static ACL
 ----     -------------    ---------   ---------          ----------
   10     Enabled          Active

 Vlan     ACL Logging      DHCP Logging      Probe Logging
 ----     -----------      ------------      -------------
   10     Deny             Deny              Off

 Vlan      Forwarded        Dropped     DHCP Drops      ACL Drops
 ----      ---------        -------     ----------      ---------
   10              0              0              0              0
```

DIA Enabled

```
C:\>arp -a
  Internet Address      Physical Address      Type
  192.168.10.1          0001.9667.3301        dynamic
```

Legitimate ARP Communication with DAI Enabled

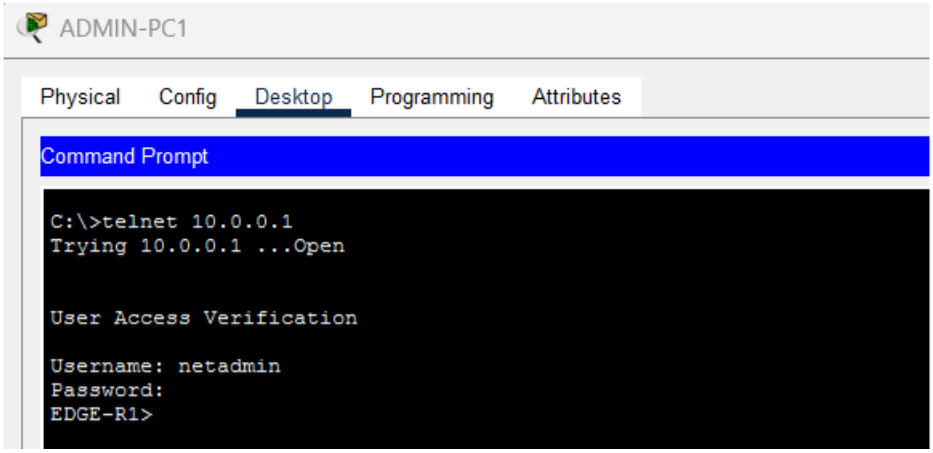
7.5 RADIUS AAA (Member 3)

Purpose: demonstrate central network-device authentication using the RADIUS server at 192.168.50.11 with local fallback. This is the practical lab implementation; the group production recommendation in Section 6 remains TACACS+ for granular device administration.

```
! RADIUS-SRV AAA service
Client: EDGE-R1
Client IP: 10.0.0.1
Shared secret: RadiusKey123
User: netadmin
Lab password: NetAdmin123

! EDGE-R1
username localadmin privilege 15 secret LocalAdmin123
aaa new-model
radius server 192.168.50.11
 address ipv4 192.168.50.11 auth-port 1645
 key RadiusKey123
aaa authentication login default group radius local
line vty 0 4
 login authentication default
exit
end
```

Verification: from ADMIN-PC1, remote login to EDGE-R1 was authenticated using the central RADIUS account and returned the EDGE-R1 prompt. Telnet is retained only as the AAA lab demonstration; Section 8.8 replaces insecure management transport with SSH.



Successful RADIUS Login

```
EDGE-R1>show ip interface brief
Interface              IP-Address      OK? Method Status                Protocol
GigabitEthernet0/0     203.0.113.2     YES manual up                    up
GigabitEthernet0/1     10.0.0.1        YES manual up                    up
GigabitEthernet0/2     192.168.70.1    YES manual up                    up
Vlan1                  unassigned      YES unset  administratively down down
EDGE-R1>
```

7.6 IPsec Site-to-Site VPN (Member 3)

Purpose: protect traffic between the remote LAN (192.168.100.0/24) and the HQ server LAN (192.168.50.0/24) using an IKEv1/IPsec tunnel between two Cisco 2811 routers. The 2811 platform was selected for the practical because it exposes crypto isakmp, crypto ipsec and crypto map commands in the available Packet Tracer image.

Plan/threat linkage: supports C3 and T5 by demonstrating encrypted transport between the remote and HQ trust zones. Named user identities and MFA are production requirements and are not emulated by this router-to-router lab tunnel.

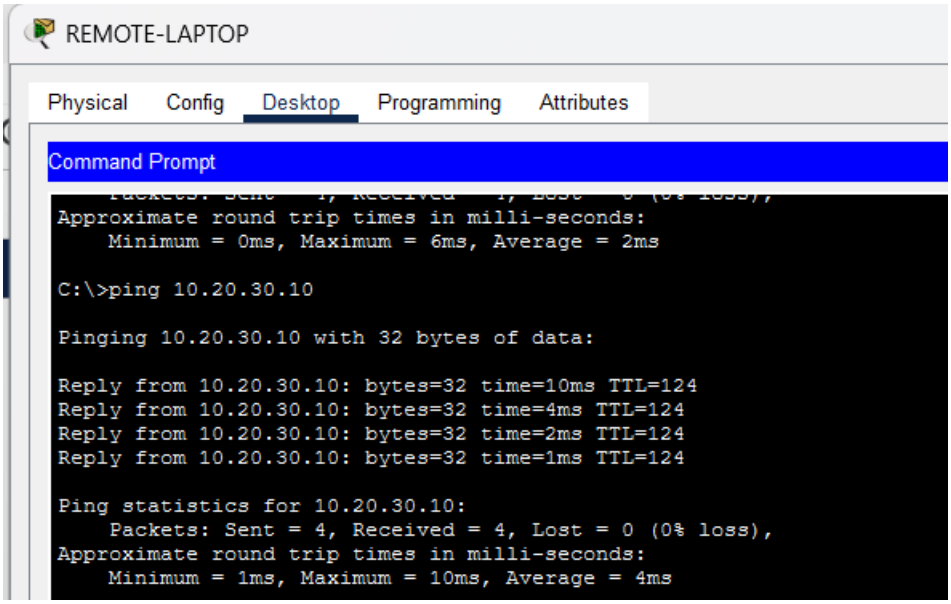
Node	Relevant addressing
REMOTE-LAPTOP	192.168.100.10/24, gateway 192.168.100.1
VPN-REMOTE-R1	Fa0/0 192.168.100.1/24; Fa0/1 172.16.200.1/30
VPN-HQ-R1	Fa0/1 172.16.200.2/30; Fa0/0 10.254.100.1/30
CORE-SW1	Gi1/0/5 10.254.100.2/30; route to 192.168.100.0/24 via 10.254.100.1
Protected HQ network	192.168.50.0/24; CORE-BANK-SRV 192.168.50.10

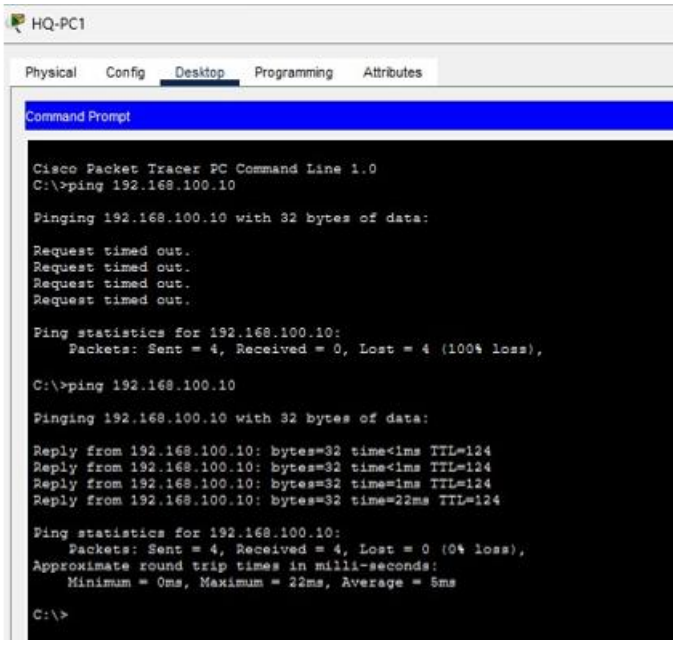
```
! VPN-REMOTE-R1
ip route 192.168.50.0 255.255.255.0 172.16.200.2
crypto isakmp policy 10
 encr aes 256
 hash sha
 authentication pre-share
 group 2
 lifetime 86400
exit
crypto isakmp key NorthbridgeVPN123 address 172.16.200.2
crypto ipsec transform-set NORTHBRIDGE-SET esp-aes esp-sha-hmac
access-list 110 permit ip 192.168.100.0 0.0.0.255 192.168.50.0 0.0.0.255
```

```
crypto map NORTHBRIDGE-MAP 10 ipsec-isakmp
 set peer 172.16.200.2
 set transform-set NORTHBRIDGE-SET
 match address 110
exit
interface fastEthernet0/1
 crypto map NORTHBRIDGE-MAP
exit

! VPN-HQ-R1
ip route 192.168.100.0 255.255.255.0 172.16.200.1
ip route 192.168.50.0 255.255.255.0 10.254.100.2
crypto isakmp policy 10
 encr aes 256
 hash sha
 authentication pre-share
 group 2
 lifetime 86400
exit
crypto isakmp key NorthbridgeVPN123 address 172.16.200.1
crypto ipsec transform-set NORTHBRIDGE-SET esp-aes esp-sha-hmac
access-list 110 permit ip 192.168.50.0 0.0.0.255 192.168.100.0 0.0.0.255
crypto map NORTHBRIDGE-MAP 10 ipsec-isakmp
 set peer 172.16.200.1
 set transform-set NORTHBRIDGE-SET
 match address 110
exit
interface fastEthernet0/1
 crypto map NORTHBRIDGE-MAP
exit
```

Required verification: first prove normal routing in both directions, then generate interesting traffic from REMOTE-LAPTOP to 192.168.50.10. Capture show crypto isakmp sa and show crypto ipsec sa. A working tunnel should show an established IKE state and non-zero encapsulation/encryption and decapsulation/decryption counters.





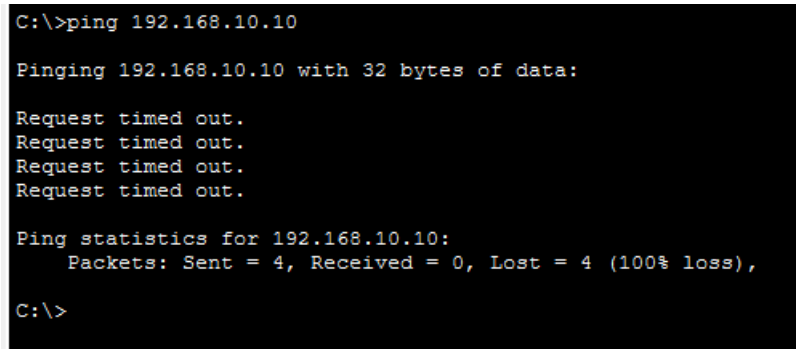
7.7 Management-Plane ACL (Member 4)

Purpose: restrict remote device-management sessions to the dedicated management subnet rather than allowing VTY access from arbitrary user networks.

```
enable
configure terminal
access-list 10 permit 192.168.60.0 0.0.0.255
line vty 0 4
 access-class 10 in
exit
end

show access-lists 10
show running-config
```

This configuration is distinct in purpose/application from Member 1's extended data-plane segmentation ACL: it uses a standard source ACL applied to the VTY management plane. The final report should include both an allowed management-source test and a denied non-management-source test.



OUTSIDE → INSIDE blocked

7.8 SSH-Only Secure Device Management (Member 4)

Purpose: replace insecure clear-text remote management with SSH version 2 and restrict VTY access to the management source network.

```
enable
configure terminal
ip domain-name northbridge.local
username admin privilege 15 secret NorthbridgeSSH123
crypto key generate rsa
! Select 1024-bit modulus in Packet Tracer when prompted
ip ssh version 2
line vty 0 4
 login local
 transport input ssh
 access-class 10 in
 exec-timeout 5 0
exit
end

show ip ssh
show running-config
```

Verification: an authorised management workstation should establish an SSH session, while a Telnet attempt should fail because transport input ssh is configured.

```
R1#show ip ssh
SSH Enabled - version 2.0
Authentication timeout: 60 secs; Authentication retries: 2
R1#
```

```
!
line aux 0
!
line vty 0 4
 access-class 10 in
 exec-timeout 5 0
 login local
 transport input ssh
!
!
!
end


R1-EDGE-FW#
R1-EDGE-FW#
R1-EDGE-FW#
R1-EDGE-FW#
R1-EDGE-FW#
R1-EDGE-FW#
```

SSH status

```
C:\>ssh -l netadmin 192.168.10.1

Password:



R1#
R1#exit

[Connection to 192.168.10.1 closed by foreign host]
C:\>telnet 192.168.10.1
Trying 192.168.10.1 ...Open

[Connection to 192.168.10.1 closed by foreign host]
C:\>
```

Telnet rejected

8. Practical Validation Summary

Configuration	Positive verification required	Current report status
Extended ACL / segmentation	ACL entries/match counters + guest-to-internal blocked	PASS - capture final screenshots
Port Security	Secure sticky MAC + violation behaviour	PASS - capture final screenshots
DHCP Snooping	Snooping enabled + VLAN 10 binding learned	PASS
Dynamic ARP Inspection	DAI enabled/trusted uplink + bindings + legitimate traffic	CONFIGURED - screenshot required
RADIUS AAA	Central account authenticates to EDGE-R1	PASS
IPsec VPN	Established IKE/IPsec SAs + end-to-end protected traffic	PENDING - do not claim PASS yet
Management ACL	Allowed management source + denied other source	EVIDENCE REQUIRED
SSH-only management	SSH succeeds and Telnet fails	EVIDENCE REQUIRED

The marking scheme places major emphasis on verification screenshots. A configuration that is correctly written but lacks evidence can drop from the Excellent band. Therefore, every final practical subsection must include the exact command/output screenshot and a functional test where applicable.

9. Limitations and Implementation Notes

- Packet Tracer device images do not expose every production Cisco feature. The selected 2911 image did not provide the intended Zone-Based Firewall command family, so the practical architecture uses segmentation and management-plane restrictions while retaining multi-firewall/zone design as the production recommendation.
- The earlier ASA VPN path exposed Packet Tracer CLI/simulation limitations. The practical VPN was therefore moved to 2811 routers because the available 2811 image supports crypto isakmp, crypto ipsec and crypto map commands.
- The practical AAA demonstration uses RADIUS, while the group production recommendation is TACACS+ for granular network-device administration. This difference is documented rather than hidden.
- DAI statistics may remain at zero in Packet Tracer despite correct enablement; the final evidence should combine feature status, trusted-interface configuration, DHCP bindings and legitimate connectivity.
- The report distinguishes verified outcomes from pending outcomes. In particular, VPN success must not be claimed until a real SA and successful protected traffic are captured.

Appendix A. Member 1 Individual Technology Proposals

Each proposal names a chosen solution, a credible alternative, why the alternative was rejected for this scenario, and the Northbridge-specific reason for the final choice. This directly targets the Excellent rubric requirement.

VPN

Chosen solution	Alternative seriously considered
IPsec VPN	SSL VPN

Why the alternative was rejected: SSL VPN is excellent for user-focused remote access but does not provide one common network-layer design for both branch/site-to-site and remote connectivity as cleanly as IPsec.

Northbridge-specific selection rationale: Northbridge has dedicated branch links, remote users and Cisco-style network infrastructure; IPsec provides a consistent network-layer protection model.

AAA

Chosen solution	Alternative seriously considered
RADIUS	TACACS+

Why the alternative was rejected: TACACS+ is stronger for granular device administration, but Member 1 prioritised a broad central authentication service that can also support network-access use cases.

Northbridge-specific selection rationale: Northbridge currently has many local accounts and needs a practical first step toward reducing local identity sprawl.

Secure Network Architecture

Chosen solution	Alternative seriously considered
Three-zone / multi-firewall design	Single perimeter firewall with VLANs

Why the alternative was rejected: A single firewall creates one enforcement point and provides weaker containment if a public-facing system is compromised.

Northbridge-specific selection rationale: Northbridge operates public banking services, sensitive internal systems, branches and new payment integrations that should not share a single trust boundary.

IDS/IPS

Chosen solution	Alternative seriously considered
Suricata-based IDS/IPS	Snort

Why the alternative was rejected: Snort is mature, but Suricata was selected for flexible multi-threaded monitoring/prevention and deployment options.

Northbridge-specific selection rationale: Northbridge needs scalable monitoring at the Internet edge and internal boundaries without assuming a single proprietary appliance.

Appendix B. Member 2 Individual Technology Proposals

Each proposal names a chosen solution, a credible alternative, why the alternative was rejected for this scenario, and the Northbridge-specific reason for the final choice. This directly targets the Excellent rubric requirement.

VPN

Chosen solution	Alternative seriously considered
WireGuard	IPsec VPN

Why the alternative was rejected: IPsec provides broader legacy/enterprise interoperability, but WireGuard was selected by Member 2 for simplicity and modern cryptography in a compact remote-user deployment.

Northbridge-specific selection rationale: Travelling staff benefit from a lightweight client model; however, this proposal was later rejected by the group because site-to-site enterprise fit mattered more.

AAA

Chosen solution	Alternative seriously considered
TACACS+	RADIUS

Why the alternative was rejected: RADIUS is effective for user/network access but offers less granular command-level control for network-device administration.

Northbridge-specific selection rationale: Northbridge needs individual accountability for infrastructure changes, so TACACS+ better supports privileged router/switch administration.

Secure Network Architecture

Chosen solution	Alternative seriously considered
DMZ + internal segmentation with dual firewalls	Single firewall with multiple VLANs

Why the alternative was rejected: A single firewall provides less separation between public services and critical banking systems.

Northbridge-specific selection rationale: An additional internal enforcement boundary reduces the chance that compromise of the public portal directly exposes the server/core zone.

IDS/IPS

Chosen solution	Alternative seriously considered
Snort	Suricata

Why the alternative was rejected: Suricata offers strong performance and flexibility, but Snort was chosen for its mature rule ecosystem and long operational familiarity.

Northbridge-specific selection rationale: Northbridge needs understandable, rule-driven network detection that can be managed by an evolving security team.

Appendix C. Member 3 Individual Technology Proposals

Each proposal names a chosen solution, a credible alternative, why the alternative was rejected for this scenario, and the Northbridge-specific reason for the final choice. This directly targets the Excellent rubric requirement.

VPN

Chosen solution	Alternative seriously considered
OpenVPN	WireGuard

Why the alternative was rejected: WireGuard is simpler but offers fewer built-in enterprise integration patterns for a mixed contractor/staff environment.

Northbridge-specific selection rationale: OpenVPN provides broad endpoint compatibility for travelling staff and external support contractors.

AAA

Chosen solution	Alternative seriously considered
TACACS+	LDAP-only authentication

Why the alternative was rejected: LDAP alone centralises identity but does not provide the same direct network-device AAA semantics and granular authorisation/accounting.

Northbridge-specific selection rationale: Northbridge requires accountable privileged administration and reduced reliance on local router/switch accounts.

Secure Network Architecture

Chosen solution	Alternative seriously considered
DMZ + segmented internal zones + dedicated payment zone	Flat VLAN-based segmentation

Why the alternative was rejected: VLAN-only segmentation without a dedicated trust-boundary policy is too weak for third-party financial integrations.

Northbridge-specific selection rationale: Northbridge is adding two payment processors, making the payment integration a new external trust boundary that requires dedicated restriction and monitoring.

IDS/IPS

Chosen solution	Alternative seriously considered
Commercial NGFW IPS	Open-source standalone IDS/IPS

Why the alternative was rejected: Open-source platforms reduce acquisition cost but require more integration, tuning and operational ownership.

Northbridge-specific selection rationale: For a financial institution with high-value customer/transaction systems, integrated prevention, visibility, central management and vendor support are strong operational advantages.

Appendix D. Member 4 Individual Technology Proposals

Each proposal names a chosen solution, a credible alternative, why the alternative was rejected for this scenario, and the Northbridge-specific reason for the final choice. This directly targets the Excellent rubric requirement.

VPN

Chosen solution	Alternative seriously considered
SSL VPN	IPsec VPN

Why the alternative was rejected: IPsec is stronger as a common site-to-site standard, but SSL VPN was selected by Member 4 where user experience and remote-user simplicity are prioritised.

Northbridge-specific selection rationale: Travelling staff and contractors need convenient remote access with minimal client complexity.

AAA

Chosen solution	Alternative seriously considered
RADIUS + directory service	TACACS+

Why the alternative was rejected: TACACS+ is superior for network-device command control, but directory-backed RADIUS can centralise identity across a broader range of user-access services.

Northbridge-specific selection rationale: Northbridge needs to reduce separate local identity stores across users and access services.

Secure Network Architecture

Chosen solution	Alternative seriously considered
Zero-trust-inspired zones with micro-segmentation	Traditional VLANs only

Why the alternative was rejected: Traditional VLANs reduce broadcast scope but still tend to create implicit trust inside each segment.

Northbridge-specific selection rationale: Northbridge contains high-value banking and payment resources, so more resource-oriented least-privilege access is a useful long-term design principle.

IDS/IPS

Chosen solution	Alternative seriously considered
Suricata	Commercial IPS appliance

Why the alternative was rejected: A commercial appliance provides simpler support and central management but increases cost and vendor dependence.

Northbridge-specific selection rationale: Suricata provides flexible strategic visibility for a security programme that may need to deploy sensors at multiple boundaries with controlled cost.

Appendix E. Consolidated Configuration Scripts

These blocks consolidate the practical syntax so it can be reviewed independently of screenshot quality. Passwords are lab-only values and must not be reused in production.

E1. CORE-SW1 Guest segmentation ACL

```
ip access-list extended GUEST-FILTER
 deny ip 192.168.40.0 0.0.0.255 192.168.10.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.20.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.30.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.50.0 0.0.0.255
 deny ip 192.168.40.0 0.0.0.255 192.168.60.0 0.0.0.255
 permit ip 192.168.40.0 0.0.0.255 any
interface vlan 40
 ip access-group GUEST-FILTER in
```

E2. STAFF-SW1 Port Security

```
interface fa0/1
 switchport mode access
 switchport access vlan 10
 switchport port-security
 switchport port-security maximum 1
 switchport port-security mac-address sticky
 switchport port-security violation shutdown
 spanning-tree portfast
```

E3. DHCP Snooping

```
ip dhcp snooping
ip dhcp snooping vlan 10
interface gi0/1
 ip dhcp snooping trust
interface range fa0/1-2
 ip dhcp snooping limit rate 10
```

E4. DAI

```
ip arp inspection vlan 10
interface gi0/1
 ip arp inspection trust
```

E5. RADIUS AAA on EDGE-R1

```
username localadmin privilege 15 secret LocalAdmin123
aaa new-model
radius server 192.168.50.11
 address ipv4 192.168.50.11 auth-port 1645
 key RadiusKey123
aaa authentication login default group radius local
line vty 0 4
 login authentication default
```

E6. Member 4 Management ACL + SSH

```
access-list 10 permit 192.168.60.0 0.0.0.255
ip domain-name northbridge.local
username admin privilege 15 secret NorthbridgeSSH123
crypto key generate rsa
ip ssh version 2
```

```
line vty 0 4
 login local
 transport input ssh
 access-class 10 in
 exec-timeout 5 0
```

E7. VPN-REMOTE-R1 IPsec

```
ip route 192.168.50.0 255.255.255.0 172.16.200.2
crypto isakmp policy 10
 encr aes 256
 hash sha
 authentication pre-share
 group 2
 lifetime 86400
crypto isakmp key NorthbridgeVPN123 address 172.16.200.2
crypto ipsec transform-set NORTHBRIDGE-SET esp-aes esp-sha-hmac
access-list 110 permit ip 192.168.100.0 0.0.0.255 192.168.50.0 0.0.0.255
crypto map NORTHBRIDGE-MAP 10 ipsec-isakmp
 set peer 172.16.200.2
 set transform-set NORTHBRIDGE-SET
 match address 110
interface fa0/1
 crypto map NORTHBRIDGE-MAP
```

E8. VPN-HQ-R1 IPsec

```
ip route 192.168.100.0 255.255.255.0 172.16.200.1
ip route 192.168.50.0 255.255.255.0 10.254.100.2
crypto isakmp policy 10
 encr aes 256
 hash sha
 authentication pre-share
 group 2
 lifetime 86400
crypto isakmp key NorthbridgeVPN123 address 172.16.200.1
crypto ipsec transform-set NORTHBRIDGE-SET esp-aes esp-sha-hmac
access-list 110 permit ip 192.168.50.0 0.0.0.255 192.168.100.0 0.0.0.255
crypto map NORTHBRIDGE-MAP 10 ipsec-isakmp
 set peer 172.16.200.1
 set transform-set NORTHBRIDGE-SET
 match address 110
interface fa0/1
 crypto map NORTHBRIDGE-MAP
```

Appendix F. Evidence Register

Evidence item	Current status	Required final action
Topology screenshot	Placeholder / representative diagram included	Insert final full Packet Tracer screenshot
ACL command + verification	Configured	Insert show access-lists + blocked guest test
Port security command + verification	Configured	Insert secure-up + violation screenshots
DHCP snooping status	Configured	Insert show ip dhcp snooping
DHCP binding table	Verified in current build	Insert final binding screenshot
DAI command + verification	Configured	Insert show ip arp inspection + binding + valid ping
AAA central authentication	Verified	Insert RADIUS server and successful login evidence
VPN IKE/IPsec SA	PENDING	Must show established SA; do not fabricate
VPN remote-to-HQ ping	PENDING	Must show successful protected path
VPN HQ-to-remote return traffic	PENDING	Capture reverse test if supported
Management ACL	Evidence required	Insert allowed/denied management source tests
SSH functional verification	Evidence required	Insert show ip ssh + SSH success + Telnet failure
Packet Tracer limitations	Documented	Keep explanations consistent in viva

Conclusion

Northbridge requires a layered security programme that reduces lateral movement, strengthens identity and accountability, protects public-facing and third-party trust boundaries, and improves detection and recovery around high-value financial assets. The proposed plan combines segmentation, firewall zoning, secure remote connectivity, central AAA, IDS/IPS, logging, patch management, awareness, tested recovery, third-party controls, physical controls and stronger account policy.

The Packet Tracer work demonstrates how these principles map to practical configurations. Member 1 enforces segmentation and endpoint-port control; Member 2 protects Layer-2 trust using DHCP snooping and DAI; Member 3 demonstrates central AAA and is completing the IPsec site-to-site tunnel; Member 4 secures the management plane with source restrictions and SSH. Before submission, the group must complete the remaining verification evidence and ensure the final .pkt file, screenshots, device names, IP addressing and report text are identical.

References

[1] Cisco. Configure a Site-to-Site IPSec IKEv1 Tunnel Between ASA and Cisco IOS XE Router. Cisco Support, updated 2023.

[2] Cisco. Cisco Secure Firewall ASA VPN CLI Configuration Guide - LAN-to-LAN IPsec VPNs.

[3] Cisco. Configuring Dynamic ARP Inspection - Catalyst 2960 Series.

[4] Cisco. Configuring Dynamic ARP Inspection - Catalyst 2960 Series, IOS 15.x.

[5] NIST SP 800-41 Rev. 1. Guidelines on Firewalls and Firewall Policy.

[6] NIST SP 800-207. Zero Trust Architecture.

[7] Sri Lanka Institute of Information Technology, Department of Computer Systems Engineering. IE3122: Network Security - Northbridge Savings & Finance Network Security Upgrade, 2026.